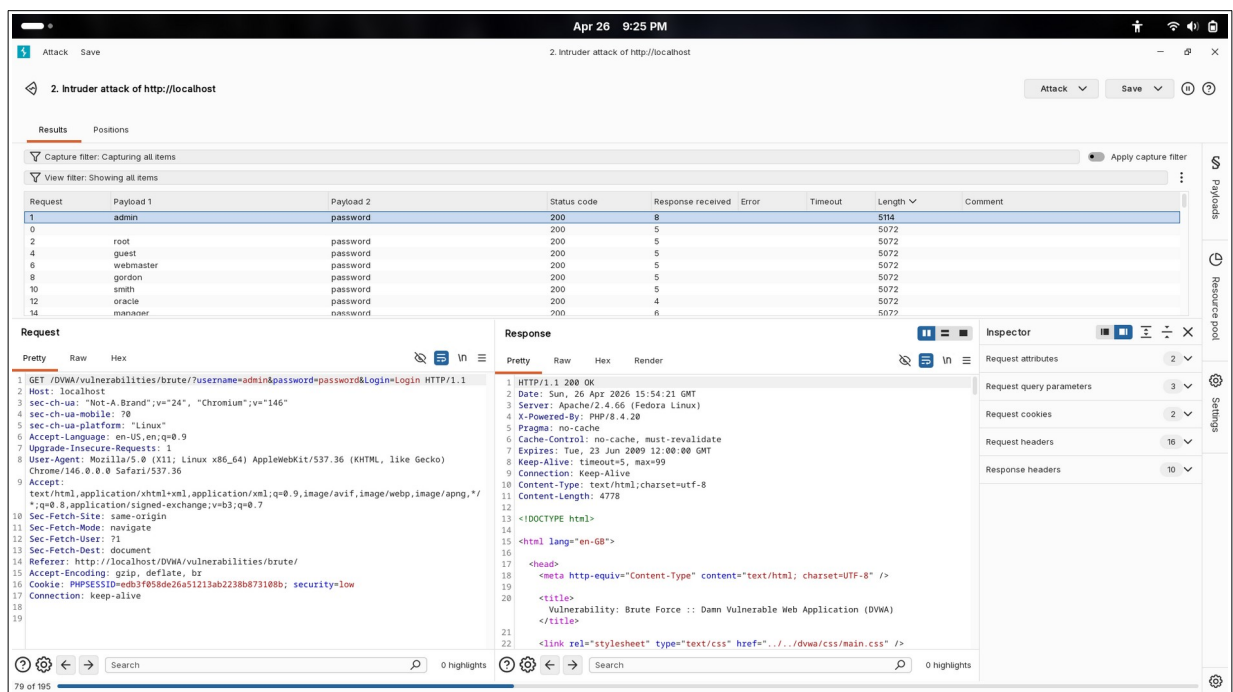


Burp Suite Deep Dive

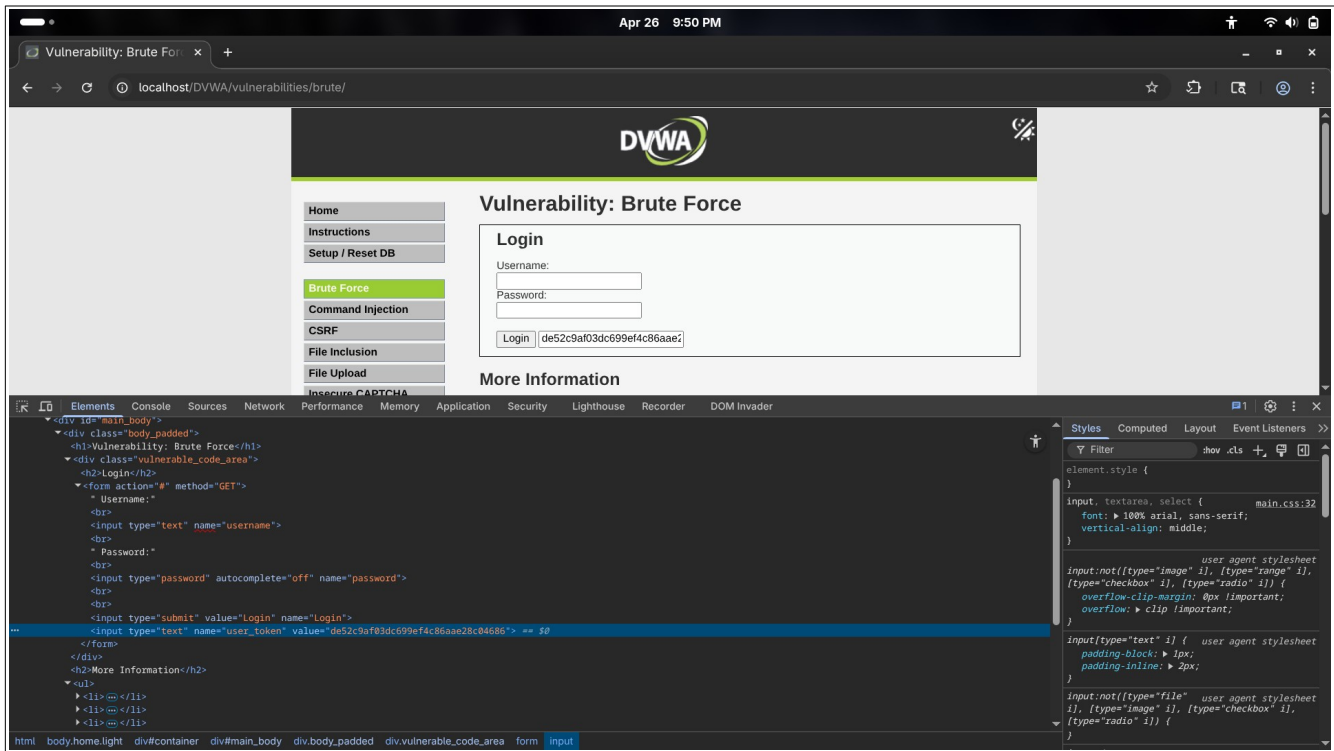
DVWA BRUTE FORCE (LOW)

1. Logged-in DVWA, chose Brute Force with security level: Low
2. Interception: ON in burpsuite
3. In DVWA, gave random username and password
4. Intercepted in Burpsuite as GET request.
5. Sent to Intruder
6. Marked the username and password, changed the attack method to Cluster Bomb Attack
7. In payload section, chose “top_username.txt” for Choice-1 (username) and “top_pass.txt” for Choice-2 (password)
8. Start Attack, after few seconds, identified an unique value in the length “5114”
9. Found the username = “admin” and password = “password”

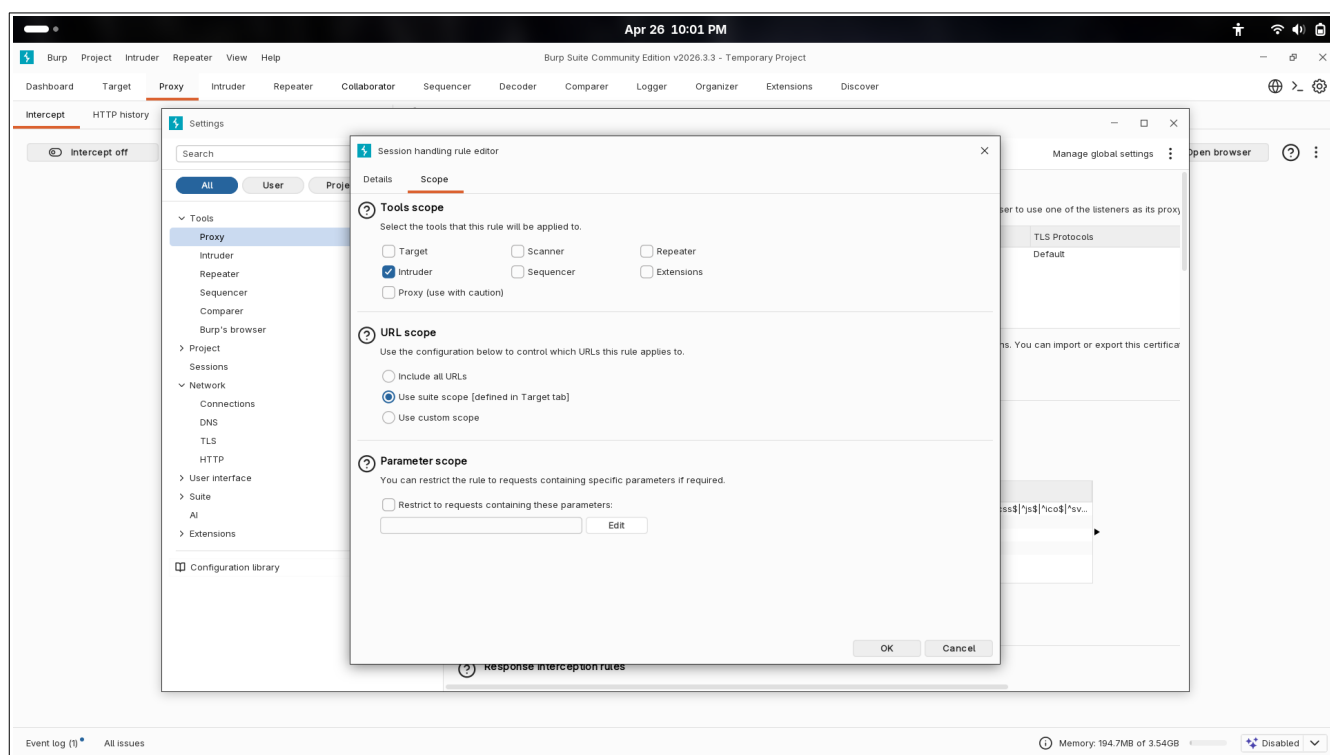


DVWA BRUTE FORCE (MEDIUM)

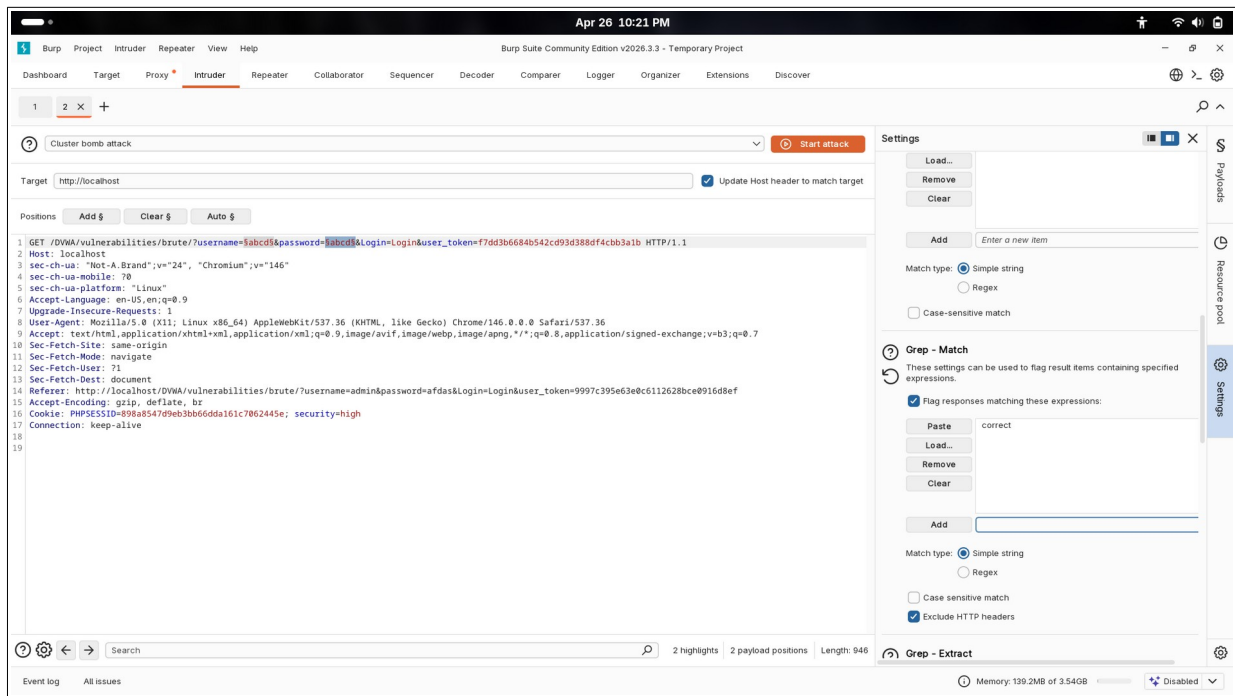
1. Logged-in DVWA, chose Brute Force with security level: Medium
2. Interception: ON in burpsuite
3. In DVWA, gave random username and password
4. Intercepted in Burpsuite as GET request.
5. Sent to Intruder
6. Marked the username and password, changed the attack method to Cluster Bomb Attack
7. In payload section, chose “top_username.txt” for Choice-1 (username) and “top_pass.txt” for Choice-2 (password)
8. Start Attack, after a minutes, identified an unique value in the length “5123”
9. This level has a time sleep of 2 seconds for each failure attempt
10. Found the username = “admin” and password = “password”



3. In DVWA, gave random username and password
4. Intercepted in Burpsuite as GET request.
5. In Burpsuite, navigated to Proxy > Proxy Settings > Sessions
6. Session handling rules > Add
7. Rule actions > Add > Run a macro
8. Add > Select the appropriate GET Request > For temporary intercept: OFF > OK
9. Macro editor > Config item
10. Search “token”, copy the name: “user_token” and paste in the Parameter Name above > OK
11. Configure macro item OK > Macro editor OK > In Session handling action editor, checkbox “Tolerate URL mismatch ..” then OK > In above navigate to Scope > In Tools Scope uncheckbox except “Intruder” > URL scope, change to “Use suite scope”, then OK.



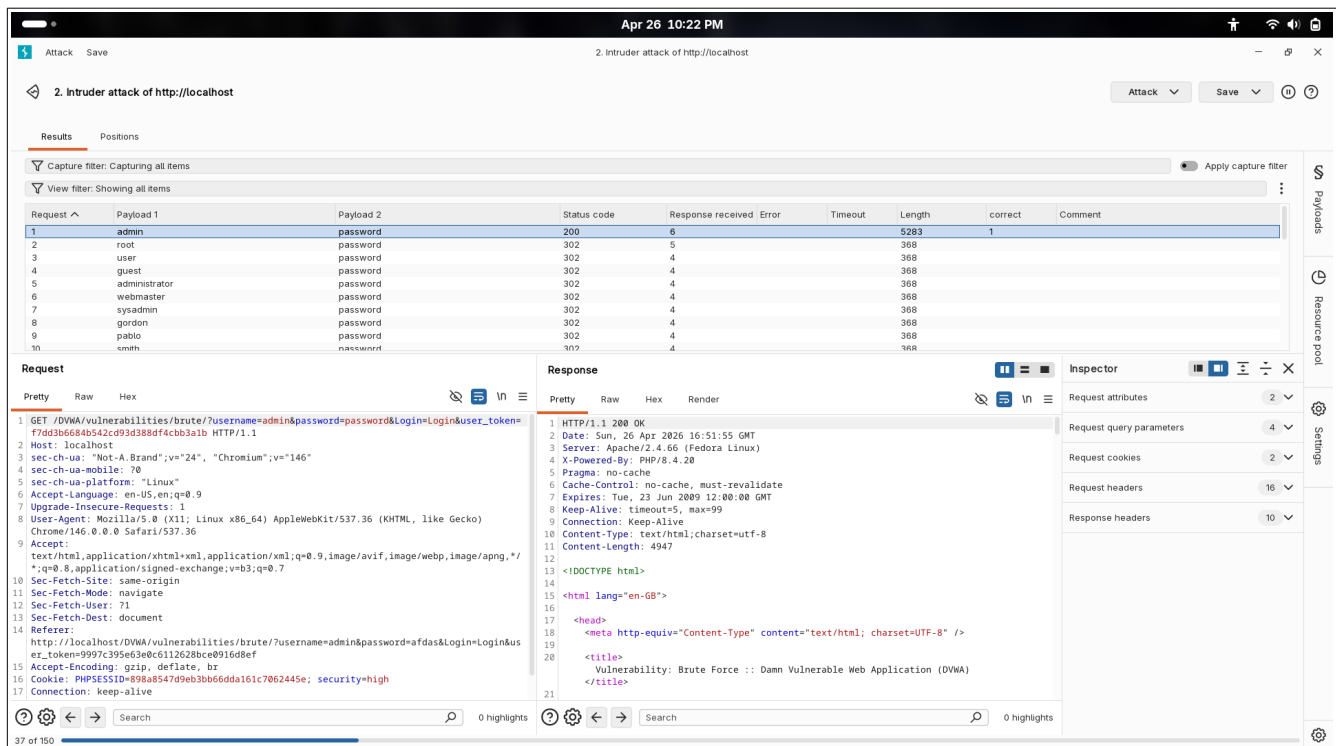
12. Again Intercept: ON, go to the DVWA site, enter random credential
13. In Intercept, again a GET request will be shown, send to Intruder and Add to Scope
15. In Intruder, Mark the username and password, changed the attack method to Cluster Bomb Attack
16. In payload section, chose “top_username.txt” for Choice-1 (username) and “top_pass.txt” for Choice-2 (password)
17. In setting section, uncheckbox “Make unmodified baseline request” and in Grep-Match, Clear, Add “correct”.



18. Start Attack, after a minutes, identified an unique value in the length “5283”

19. The user_token or session_token is used to prevent automated brute-force by making sure whether each login request is unique.

20. Found the username = “admin” and password = “password”



Why Intruder ?

1. In all three (low, medium, high), we had list of default or most common list of username and password.
2. Intruder is used when we automate a task with just changing the values.

Why Intruder – Cluster Bomb Attack ?

1. Cluster bomb uses permutations, like combining a username with all the passwords
2. So, in low, medium Cluster Bomb attack can be used directly
3. For Hard, we need to config Scope, Macros, Session Handling, etc., as the user_token changes for each and every attempt.

SNIPER : Used when a particular value is confirmed, and the other value has to be brute-forced

BATTERING RAM: Suspecting when the both values are same. Eg., for username : password, admin:admin, etc.

PITCHFORK: Used when the values has to move simultaneously. This method can also be used in DVWA BRUTE FORCE (Hard). It can act as keeping one value of admin fixed, changing the password and the session token simultaneously, then again changing the value of admin after one complete run of all passwords.